Purpose

This is a step-by-step procedure to build/configure the offline Root Certificate Authority and later sign the Intermediate CA's Certificate Signing Request.

In layman terms, the offline Root CA will "sign" the Intermediate CA as a "representative" within the domains. After which, further certificate signing with be done with the Intermediate CA

Scope

In-Scope

- Installation of AD CS role as a Standalone Root
- Configuration of private key
- Root Extension Setup
- Signing the Intermediate CA's Certificate Signing Request
- Setting validity periods of root certificate
- Decommissioning of Root CA

Out-of-Scope

- Internal configuration of Intermediate CA or IIS Web Server setup

Requirements

Permissions: Local Adminstrator

Isolated dedicated VM for Windows Server that will be taken offline after complete initialization

Software: Windows Server 2019 or higher

Files: CAPolicy.inf

System must not be joined to the [INTERNAL-ORG] domain

Procedure

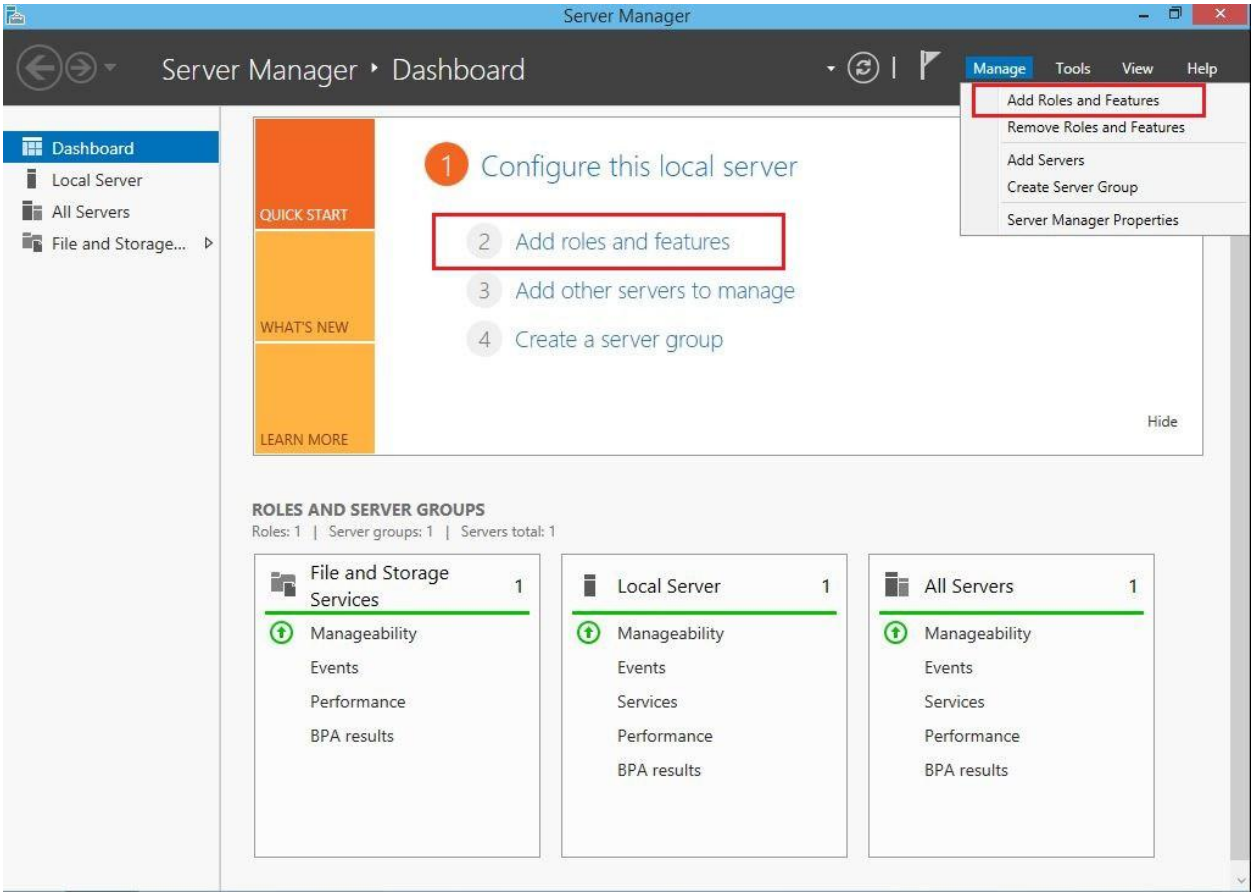
Pre-Configuration

1. Log into the standalone server as Local Administrator
2. In a new file **C:\Windows\CAPolicy.inf**, have the following content:
    a. You may edit the Root CA's certificate renewal period as necessary with the values:
        i. **RenewalValidityPeriod**
        ii. **RenewalValidityPeriodUnits**

```
[Version]

Signature="$Windows NT$"

[PolicyStatementExtension]

Policies=InternalPolicy

[InternalPolicy]

OID=1.2.3.4.1455.67.89.5

Notice="Legal Notice: [INTERNAL-ORG] Root CA. Physical access necessary for modifications"

URL=https://pki.corp.contoso.com/pki/cps.txt

[Certsrv_Server]

RenewalKeyLength=4096

RenewalValidityPeriod=Years

RenewalValidityPeriodUnits=10

CRLPeriod=Years

CRLPeriodUnits=5

LoadDefaultTemplates=0

AlternateSignatureAlgorithm=1

[CRLDistributionPoint]
```

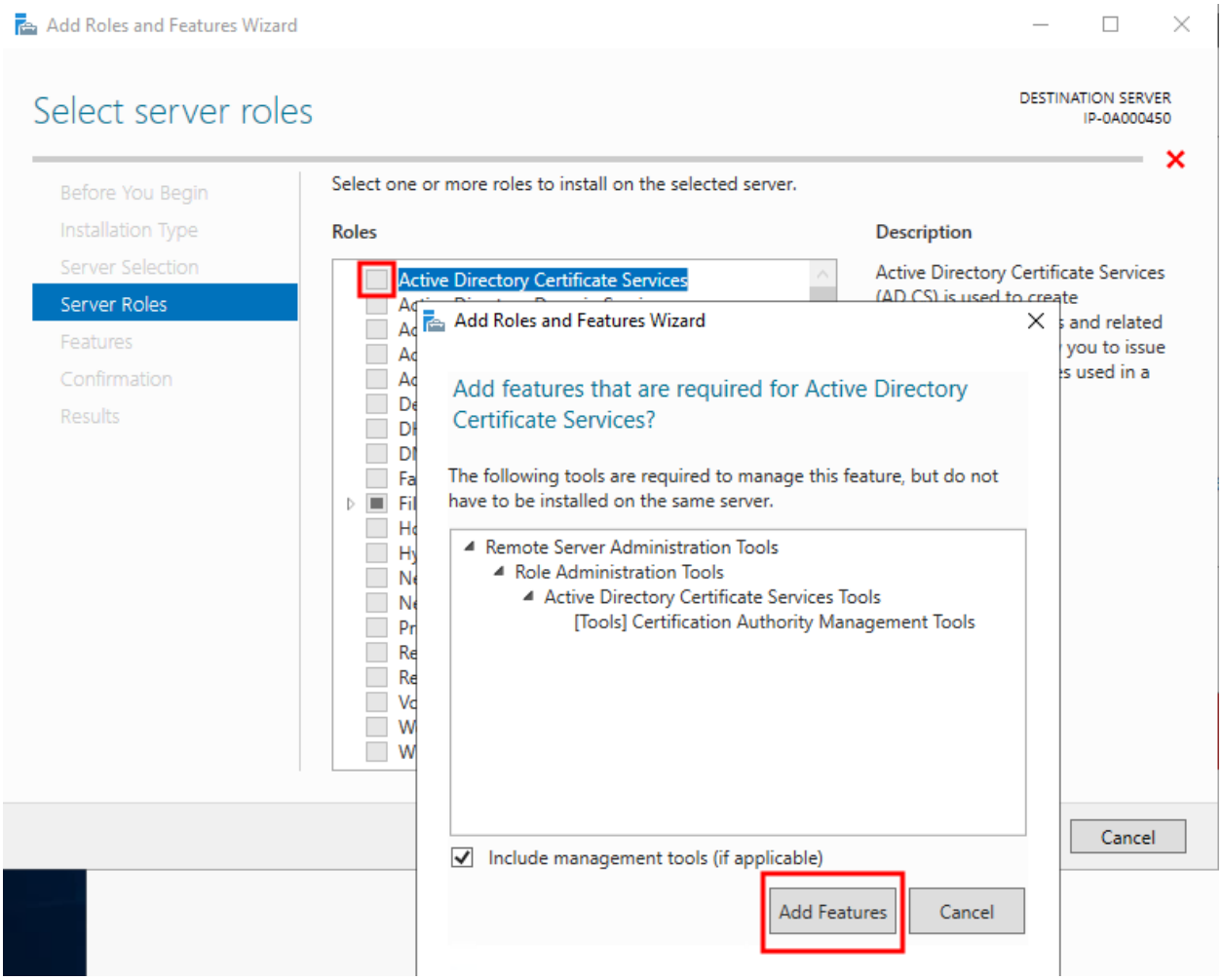
Root CA Role Installation

1. Open **Server Manager -> Manage -> Add Roles and Features**



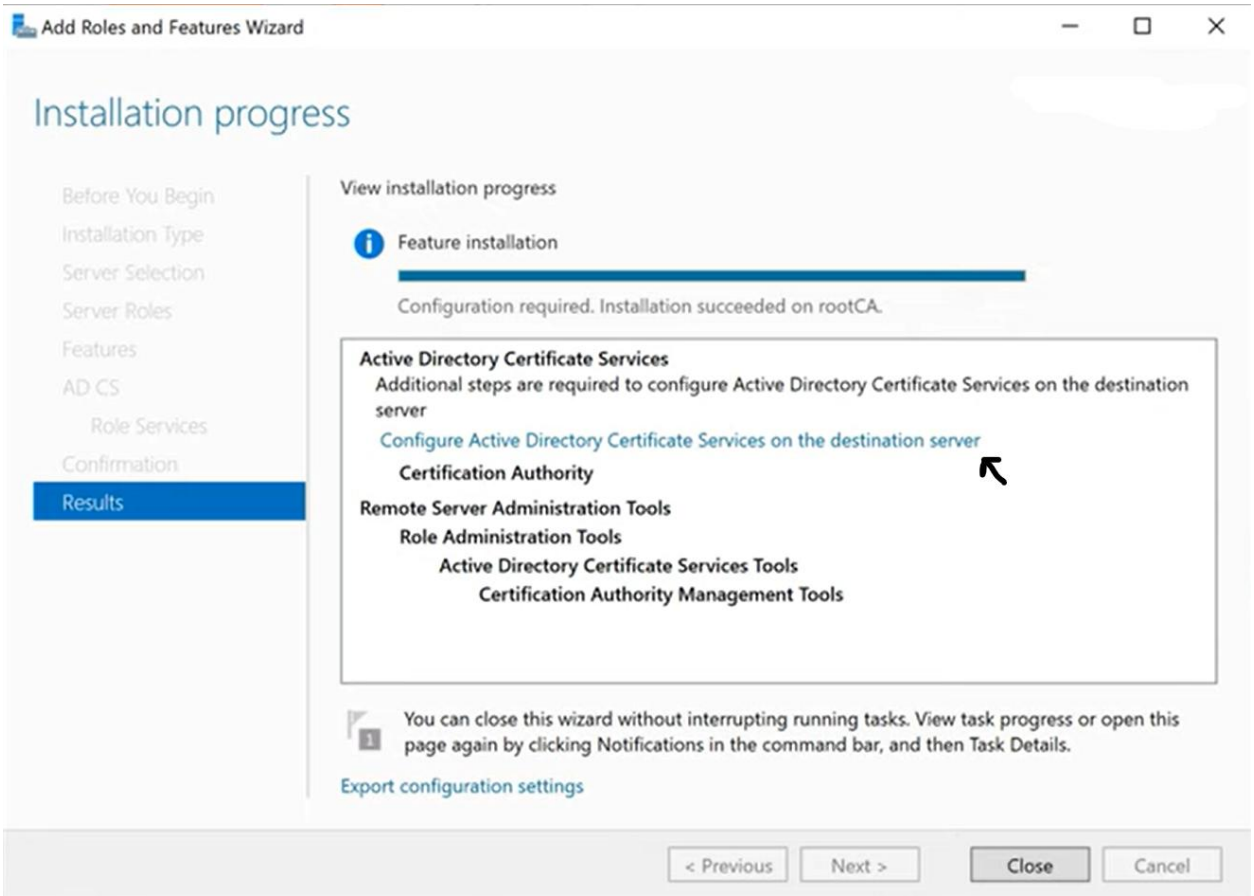
2. In the **Add Roles and Features Wizard**, accept defaults until **Server Roles**

3. **In Server Roles,** add the role **Active Directory Certificate Services** and click **Add Features**



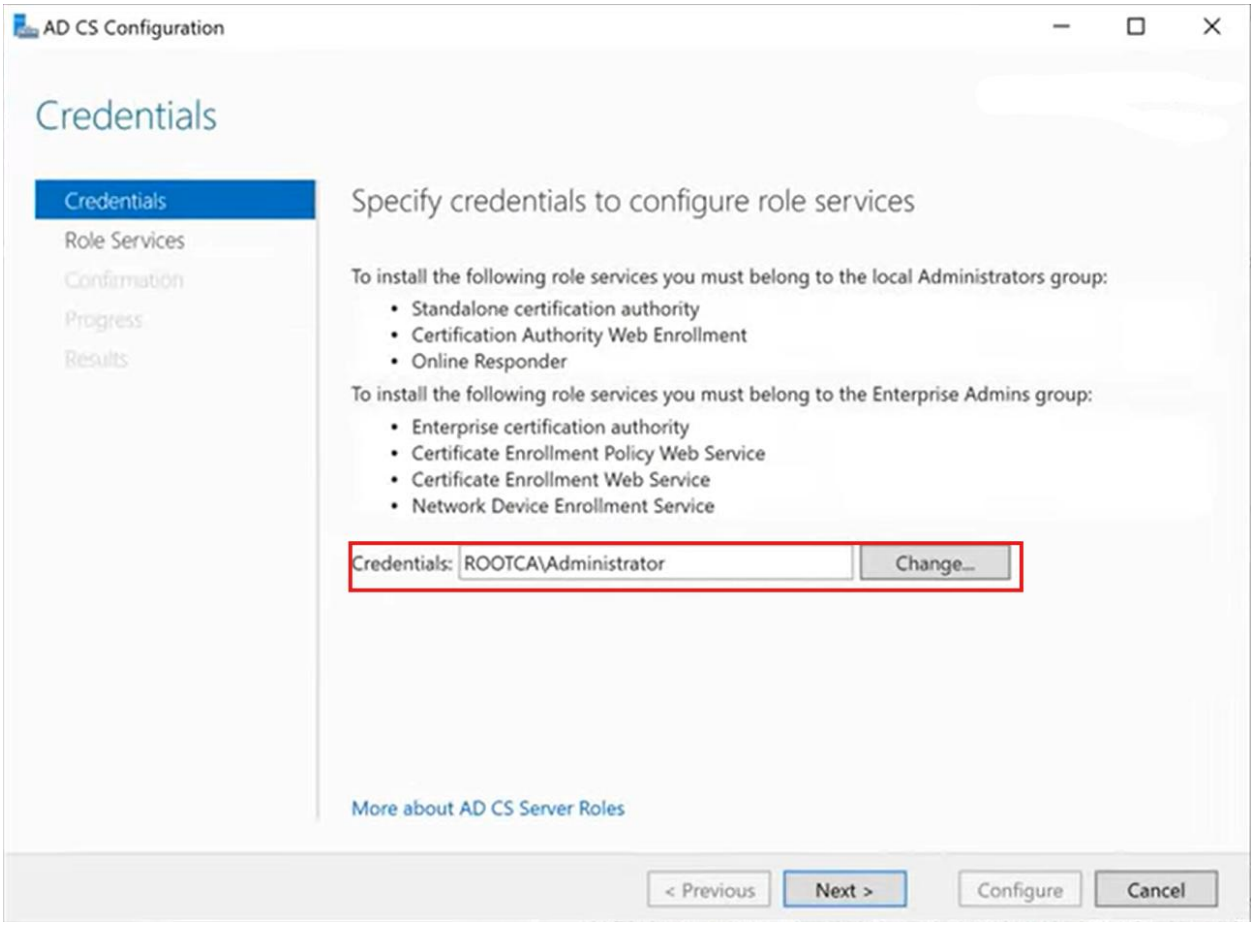
4. Accept all defaults and install

5. Once the installation is finished, on progress screen, click **Configure Active Directory Certificate Service on the destination server**

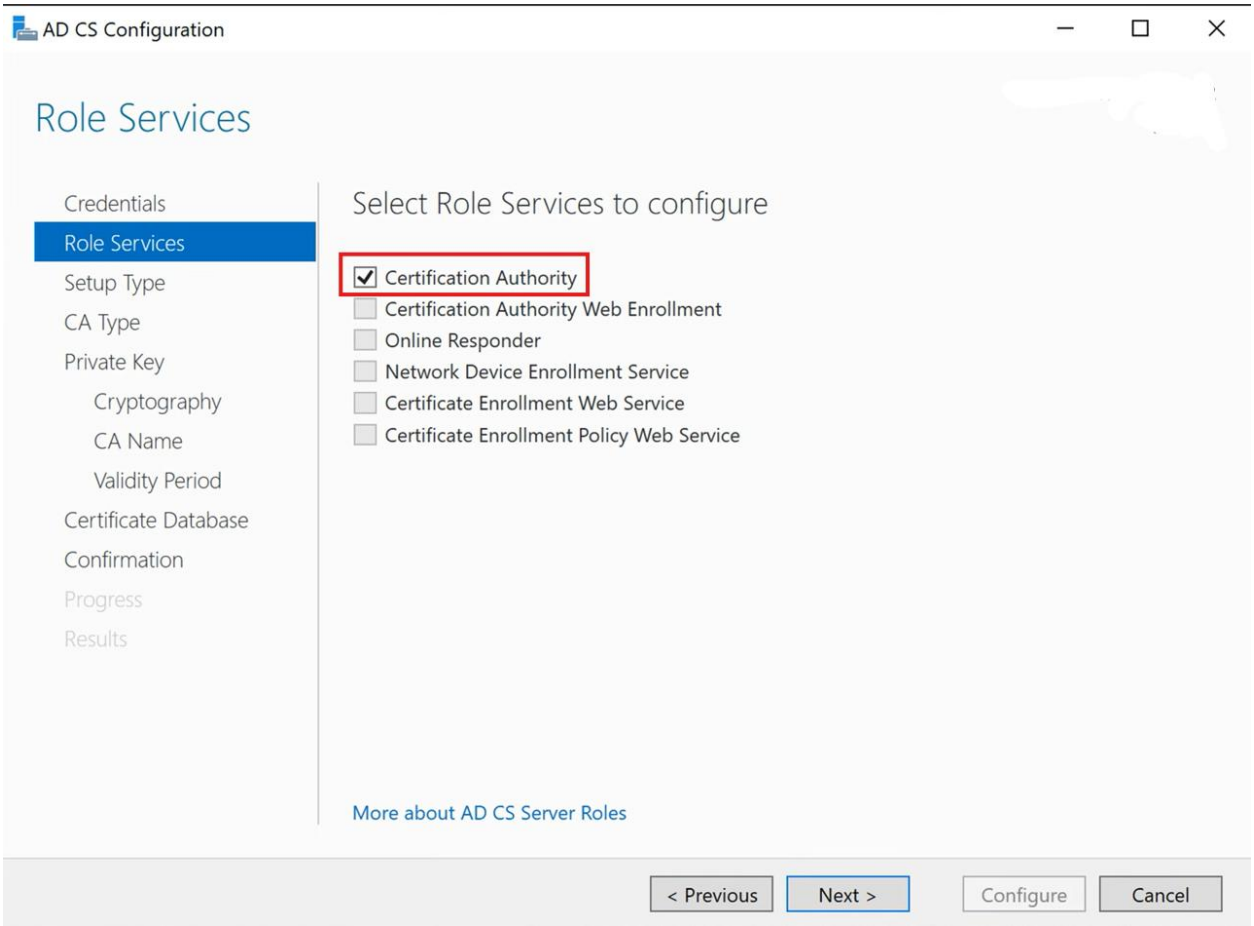


Post-Installation Role Configuration

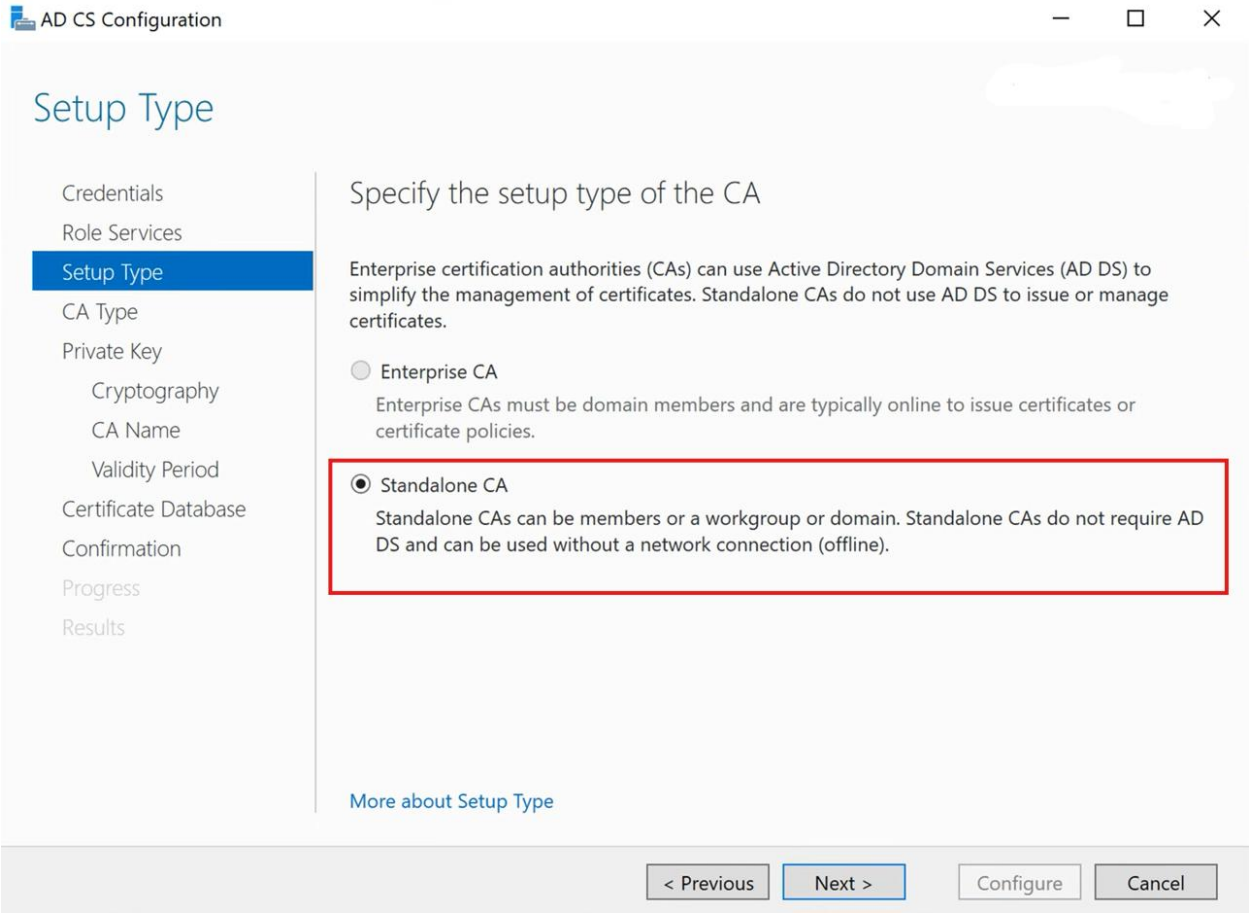
1. Ensure the **Credentials** are for the **Local Administrator account** (following is an example)



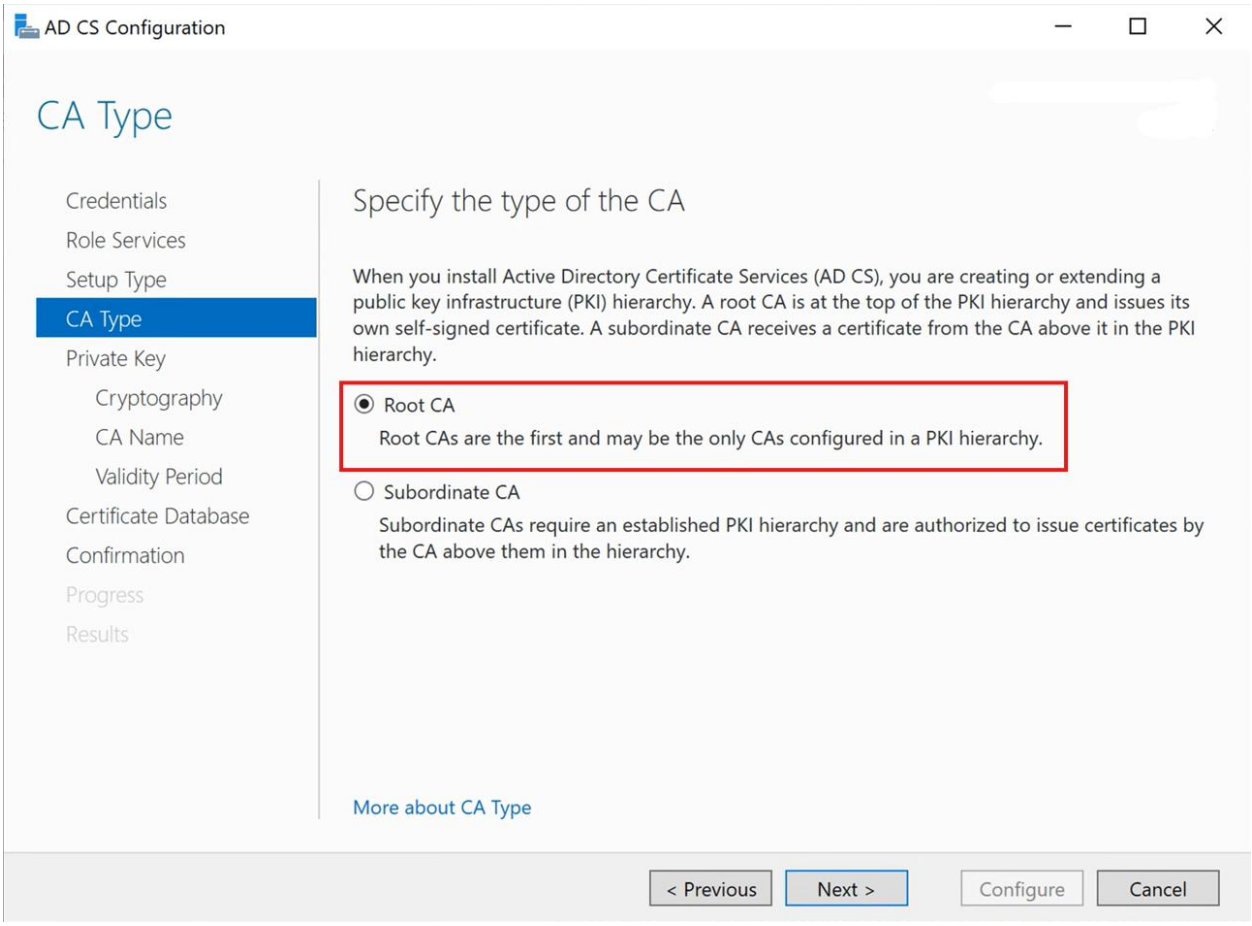
2. For **Role Services**, check **Certification Authority**



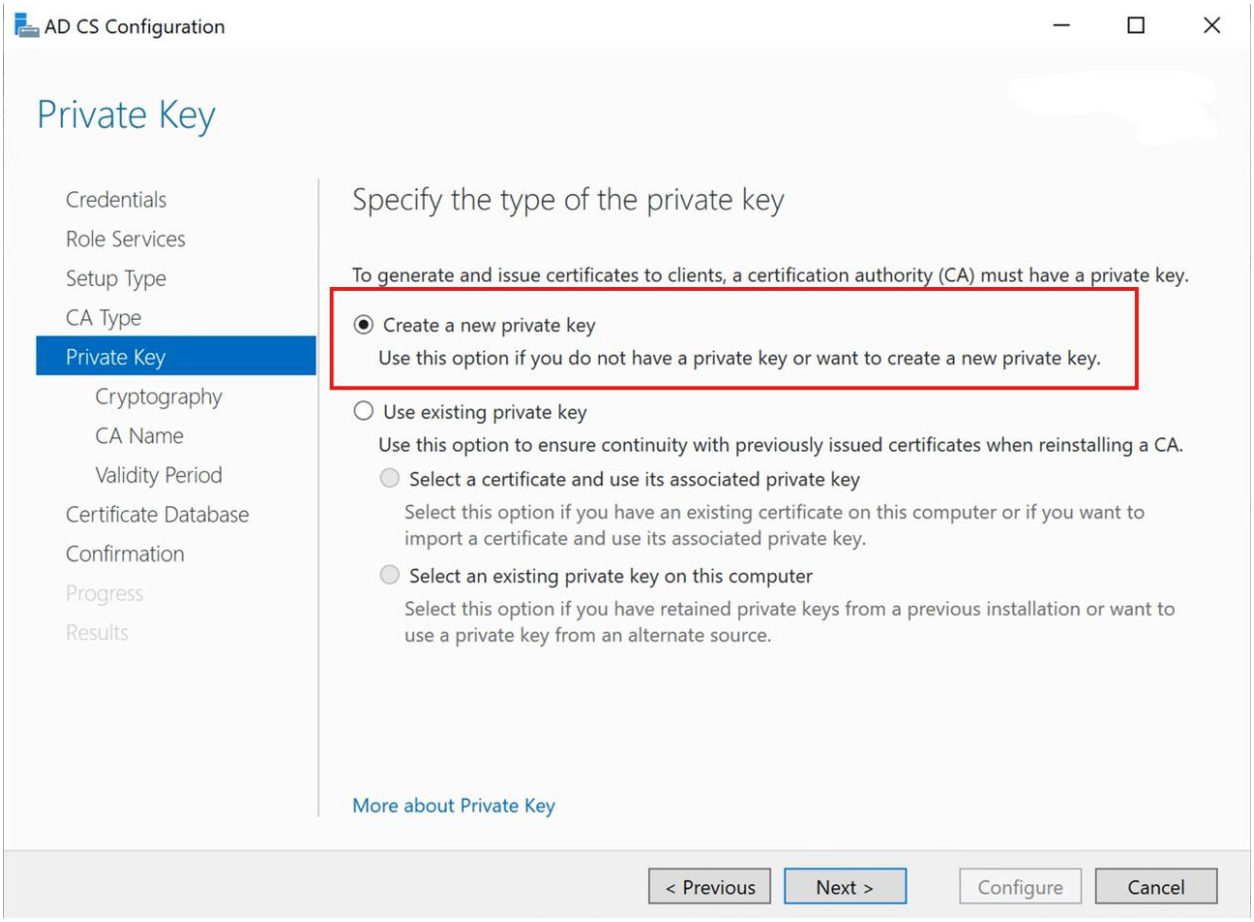
3. For **Setup Type**, select **Standalone CA**



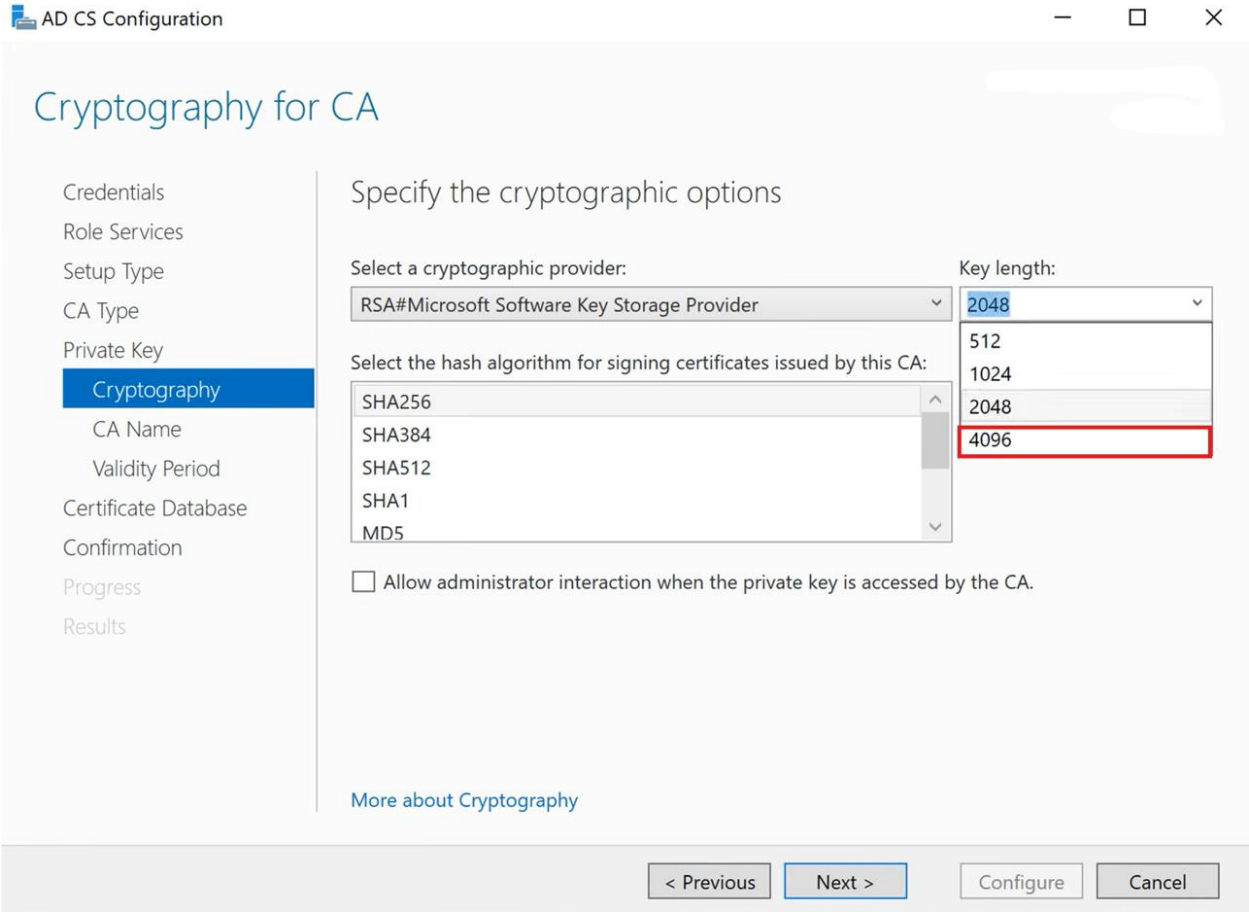
4. For **CA Type**, select **Root CA**



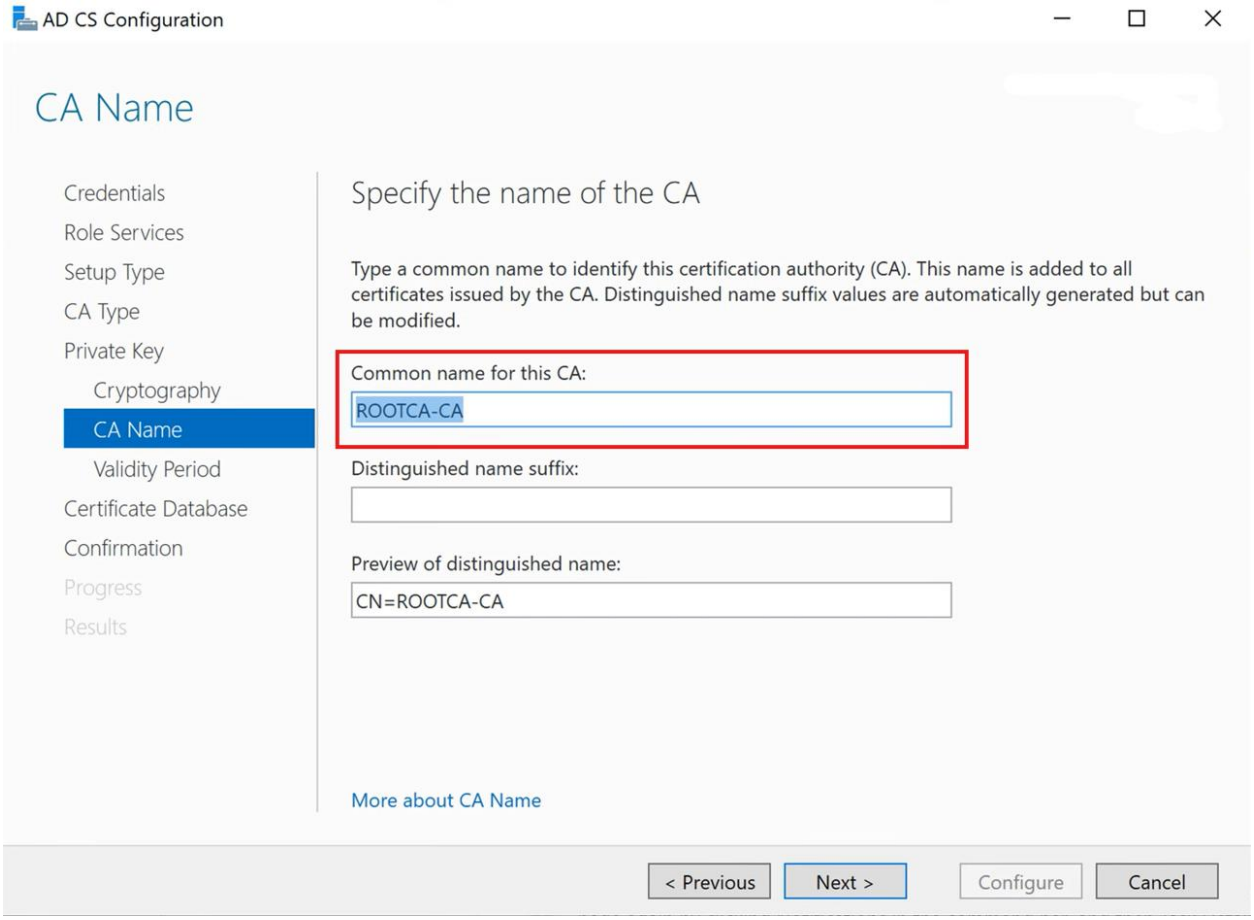
5. For **Private Key**, select **Create a new private key**



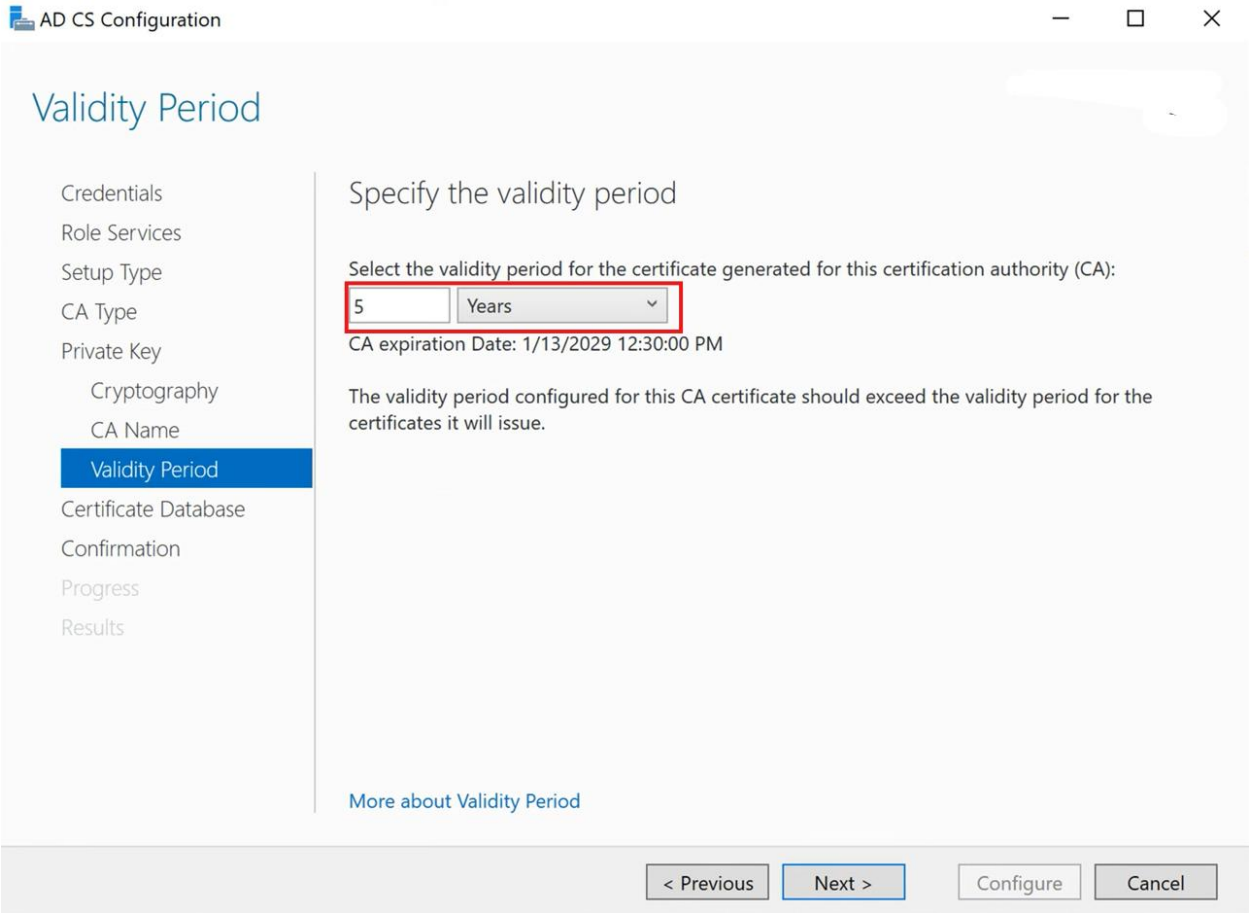
6. For **Cryptography**, select the key length **(preferably 4096)**



7. For **CA Name**, set the Common name as **[INTERNAL-ORG]-ROOTCA-CA** (can be changed for better distinction)

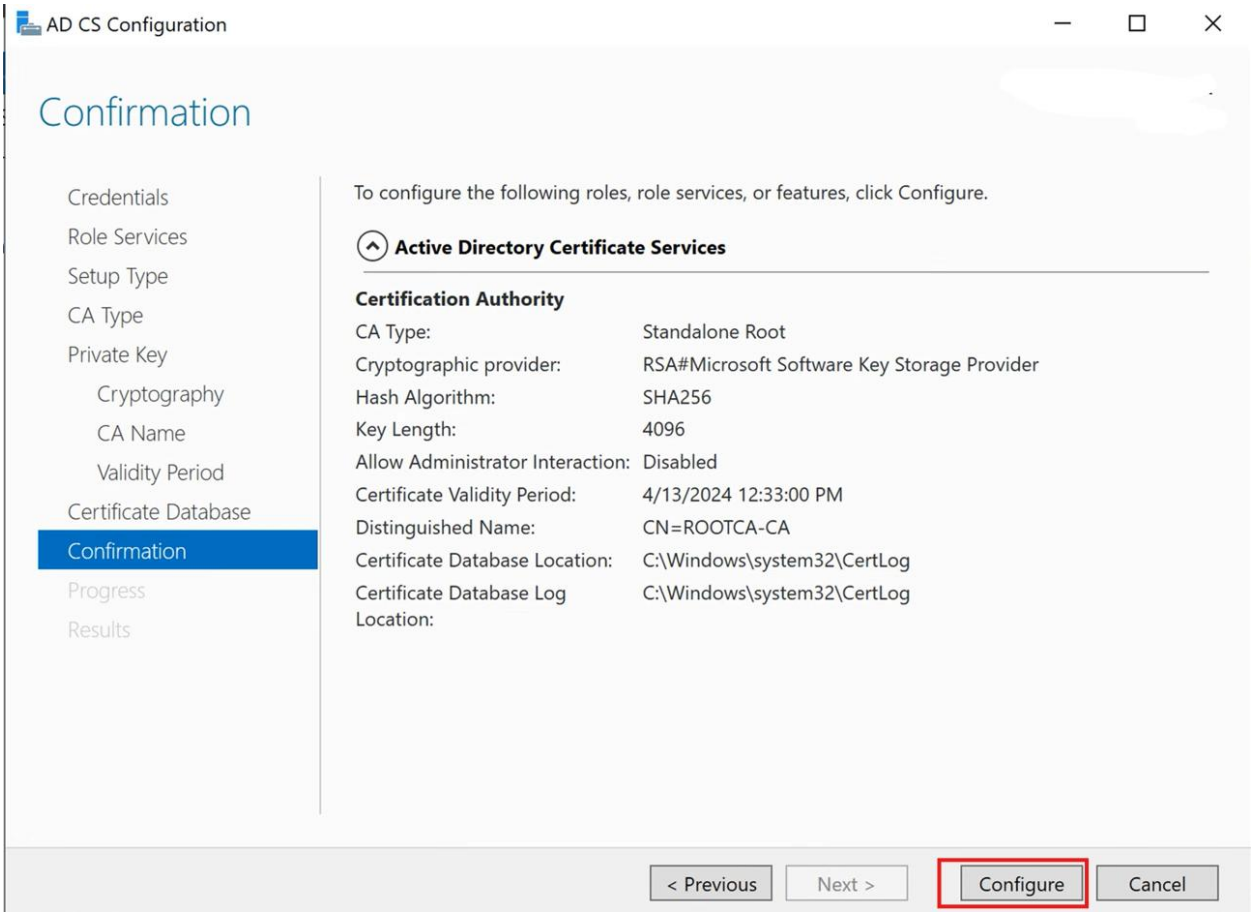


8. For **Validity Period**, match the time to the renewal validity period listed in **C:\Windows\CAPolicy.inf**



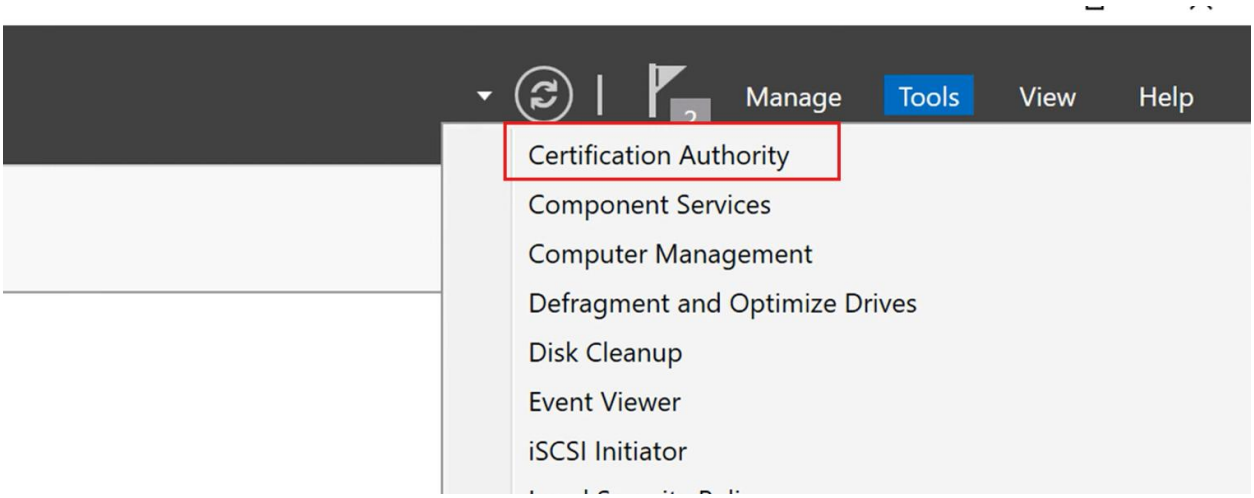
9. For **Certificate Database**, leave as default

10. Confirm configuration and click **Configure**

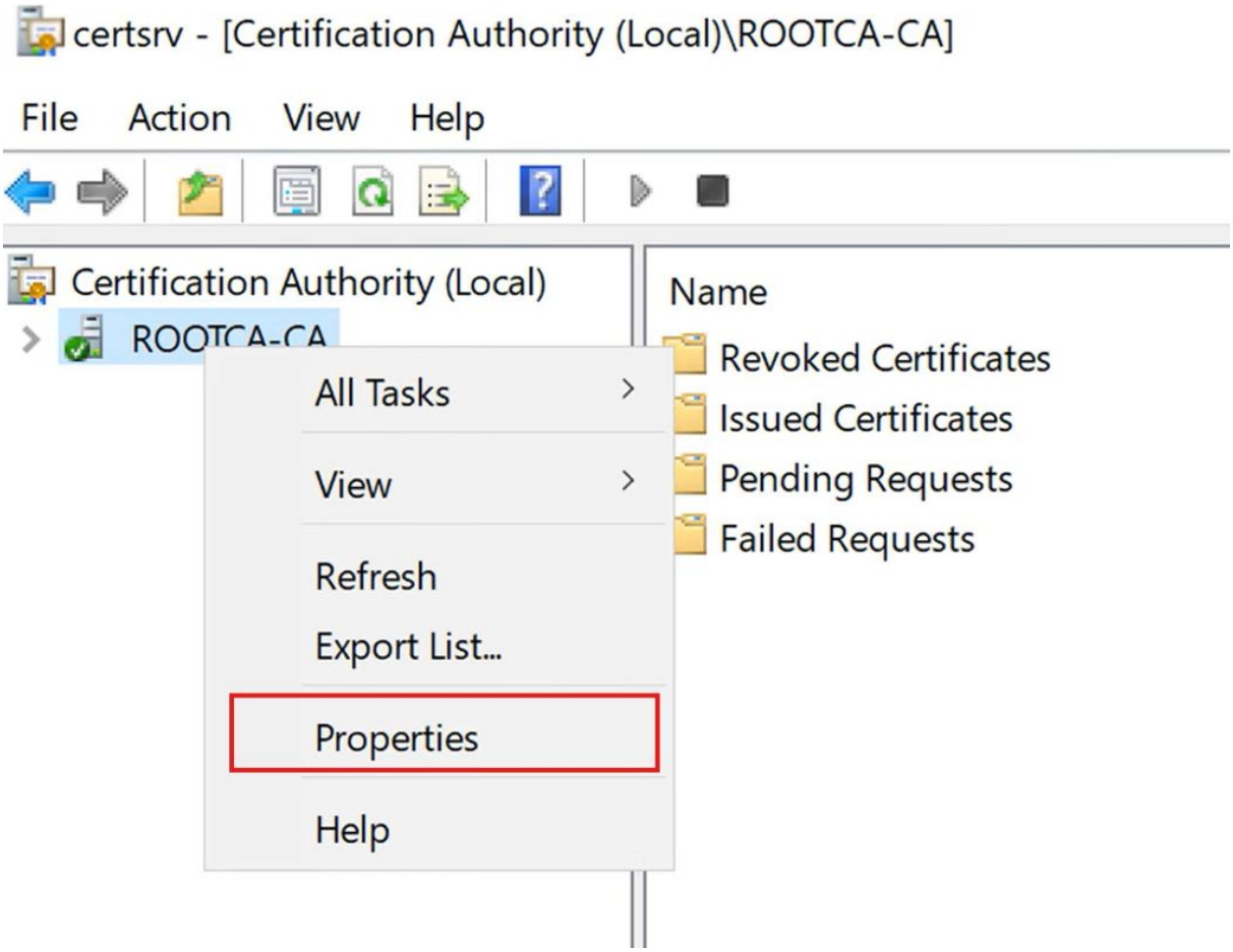


Configuring Root CA Extensions

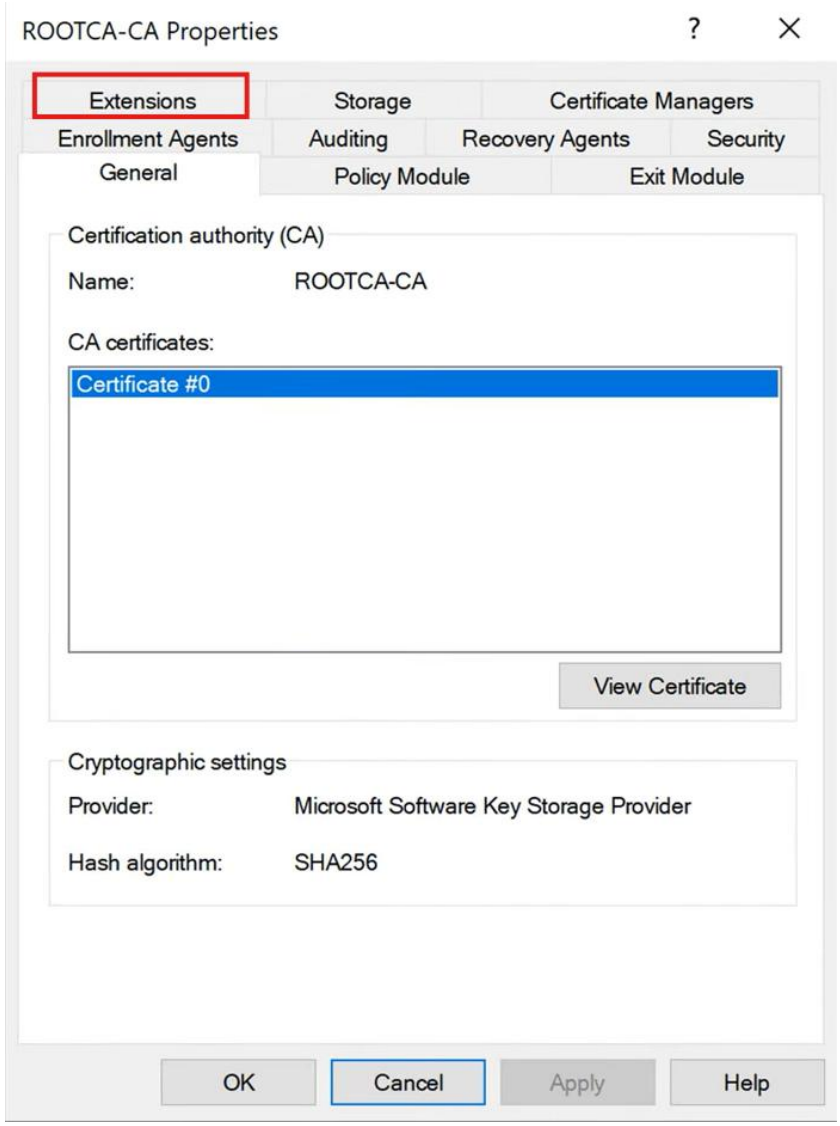
1. On **Server Manager**, go to **Tools -> Certification Authority**



2. **Right-Click** on our **CN** for our root CA and select **Properties**



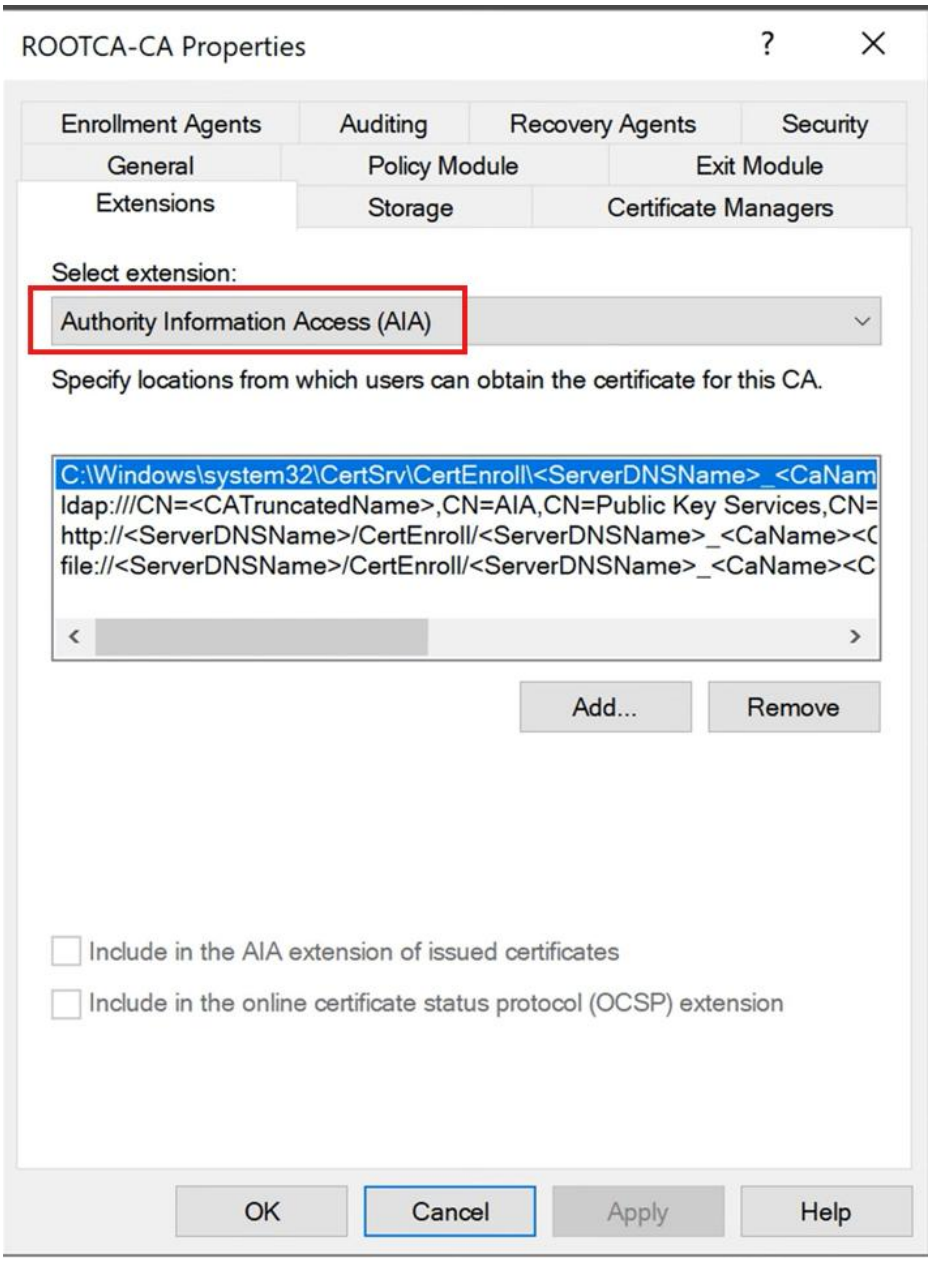
3. In the **Properties** box, select the **Extensions** tab



4. With the **CRL Distribution Point (CDP)** extension selected, have only the following entries available:
    a. The C:\ entry
    b. [Change the FQDN] http://INTERCA.[INTERNAL-ORG].local/CertEnroll/<CaName><CRLNameSuffix><DeltaCRLAllowed>.crl
    c. For the http entry, check **Include in CRLS** and **Include in the CDP**

    WHEN APPLYING CHANGES, DO NOT RESTART SERVICES

5. With the **Authority Information Access (AIA)** extension selected, have only the following entries available:
    a. The C:\ entry
    b. [Change the FQDN] http://INTERCA.[INTERNAL-ORG].local/CertEnroll/<CaName><CertificateName>.crt



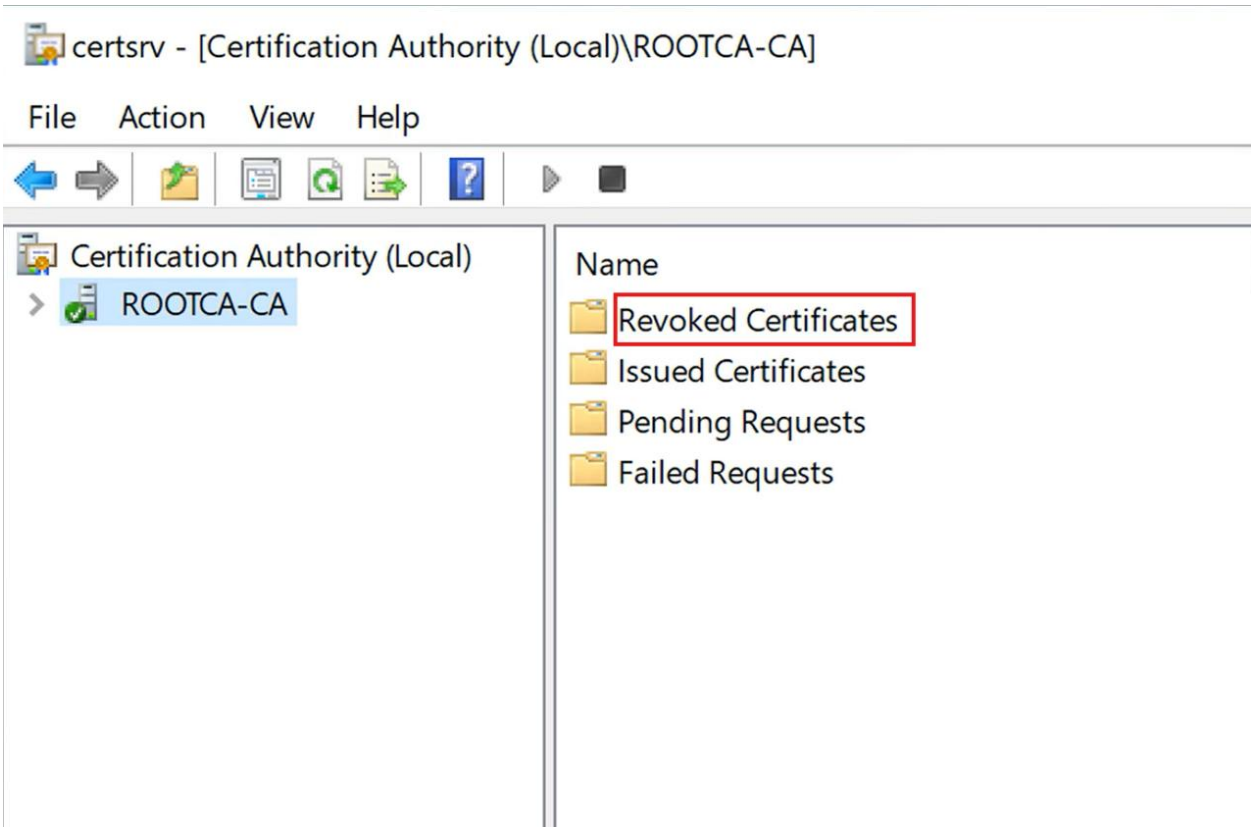
c. For the http entry, check **Include in the AIA extension…**

You can now restart the service when applying changes

Exporting the Root Certificate and Root Revocation List

The certificate should already be available, so we need to get the revocation file.

1. On **certsrv, right-click Revoked Certificates**, go to **All Tasks**, **click Publish**

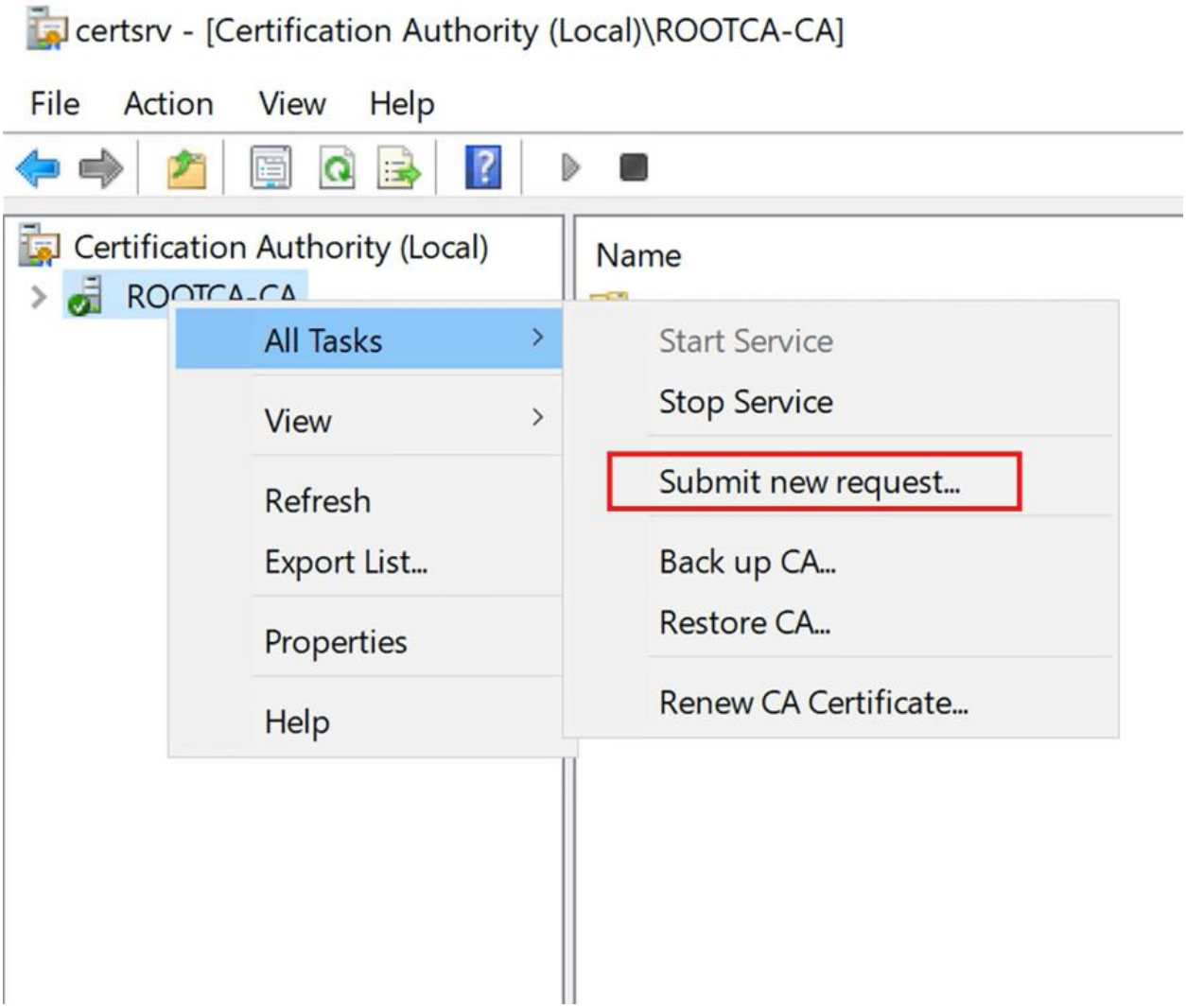


2. Both the root certificate file (.cer) and the root revocation list file (.crl) should be found under **C:\Windows\System32\CertSrv\CertEnroll**
3. Transfer both files onto a secure media to later be transferred to the Intermediate CA server.

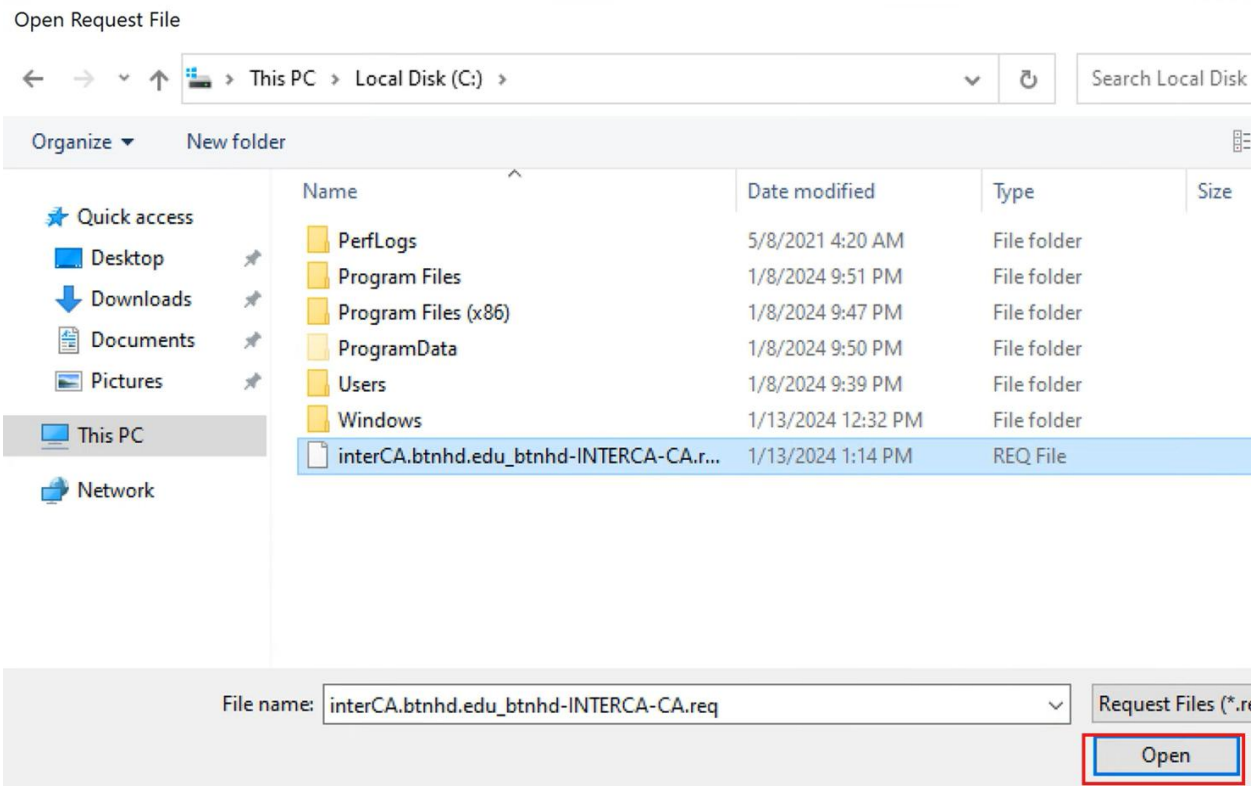
Signing The Intermediate CA request and Exporting

After the Intermediate CA server has been built/configured and its CSR has been exported

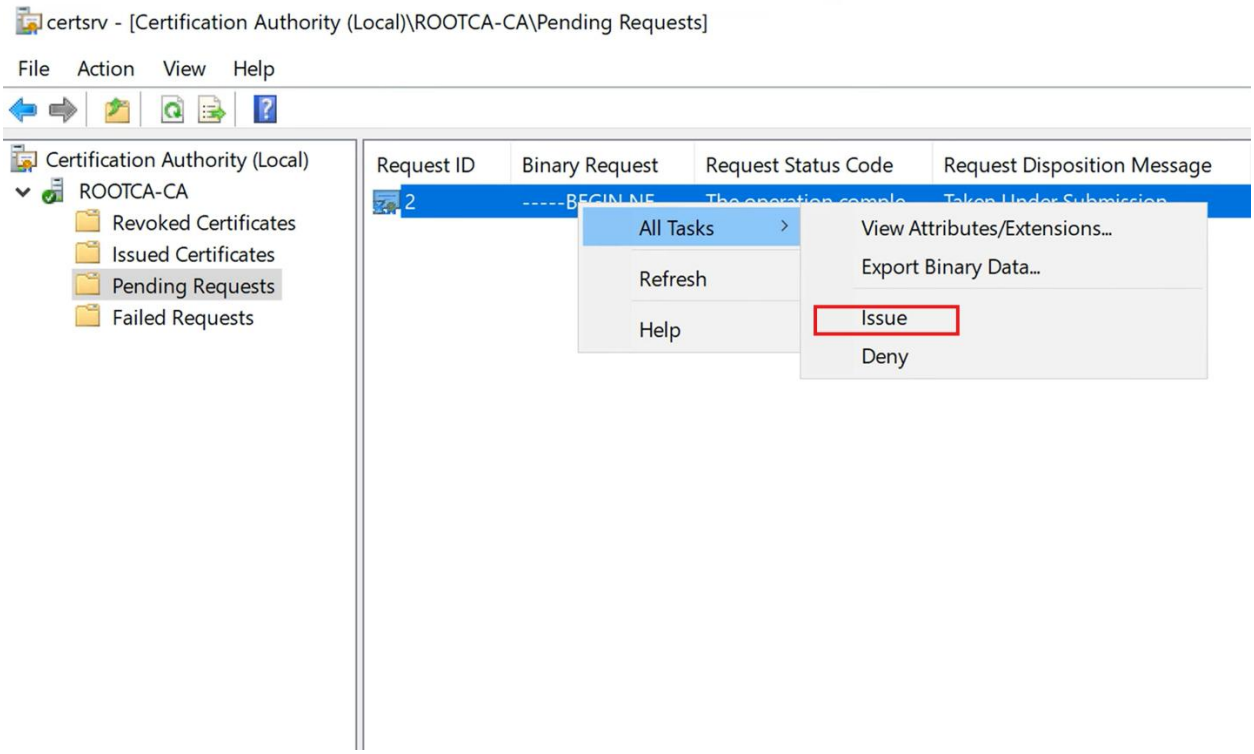
1. Mount the secure media containing the Intermediate CA's **.req** file
2. Copy over the **.req** file onto **C:**
3. Open the **Certificate Authority Console (certsrv.msc)**
4. **IF wish to specify the validity period of the Inter CA**
    a. In admin CMD: certutil -setreg CA\ValidityPeriodUnits (**number**)
    b. In admin CMD: certutil -setreg CA\ValidityPeriod "Years"
    c. To apply changes: net stop certsvc && net start certsvc
5. **Right-click** our **CA Name**, go to **All Tasks** and click **Submit new request...**



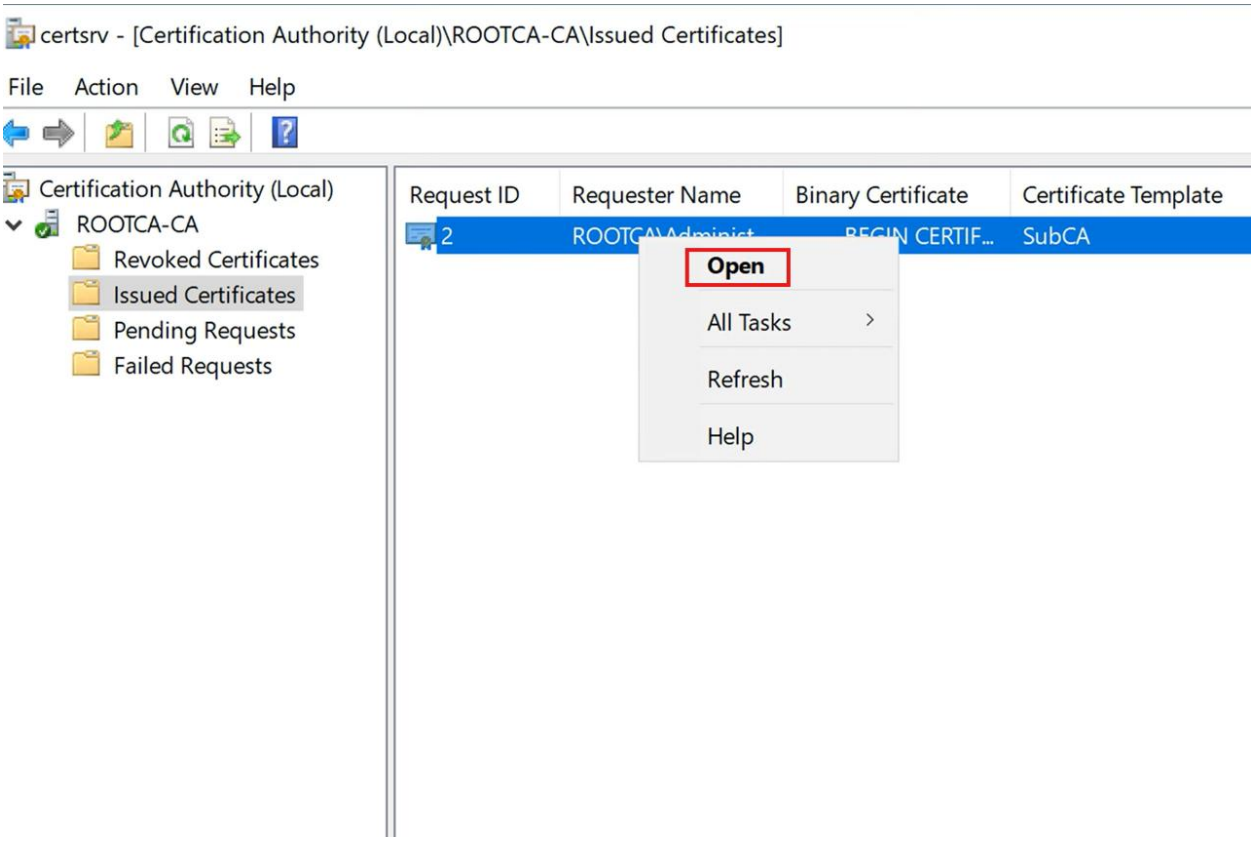
6. In the **Open Request File** window, search and open our imported **.req** file



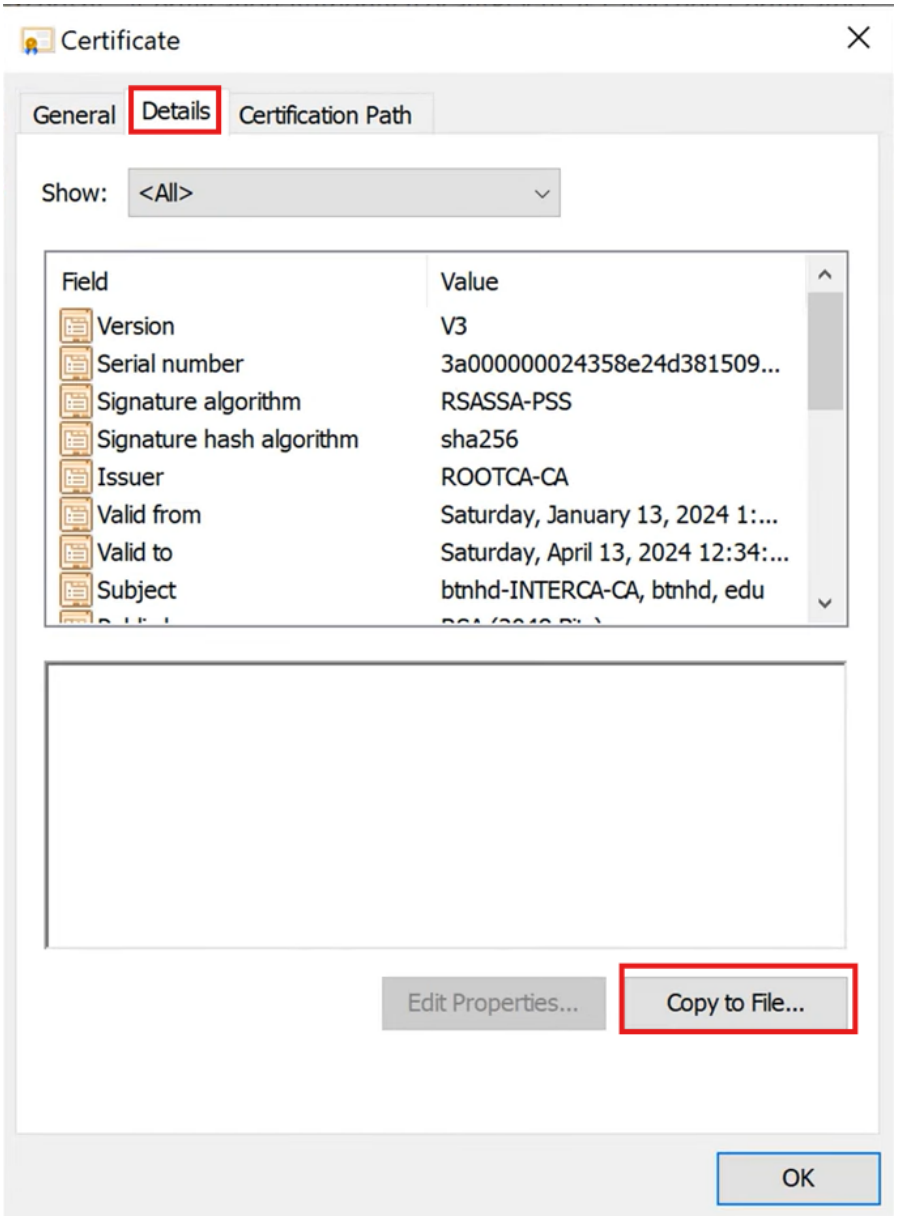
7. In the **Certificate Authority Console**, go to **Pending Requests**, **right-click** the request, go to **All Tasks**, and click **Issue**



8. In the **Certificate Authority Console**, go to **Issued Certificates**, **right-click** the certificate, and click **Open**

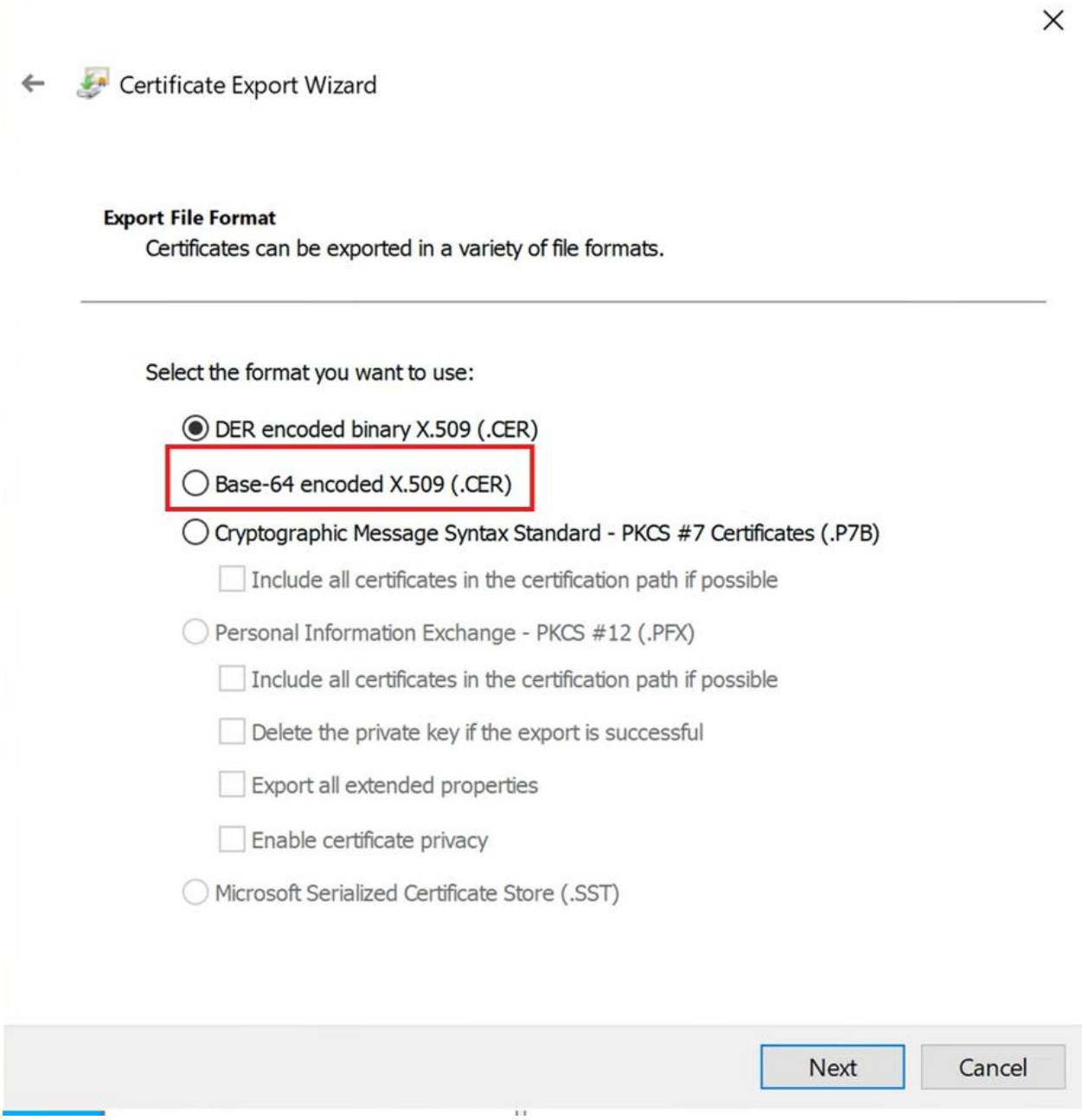


9. In the **Certificate** window, go to **Details** tab and **click Copy to File...**



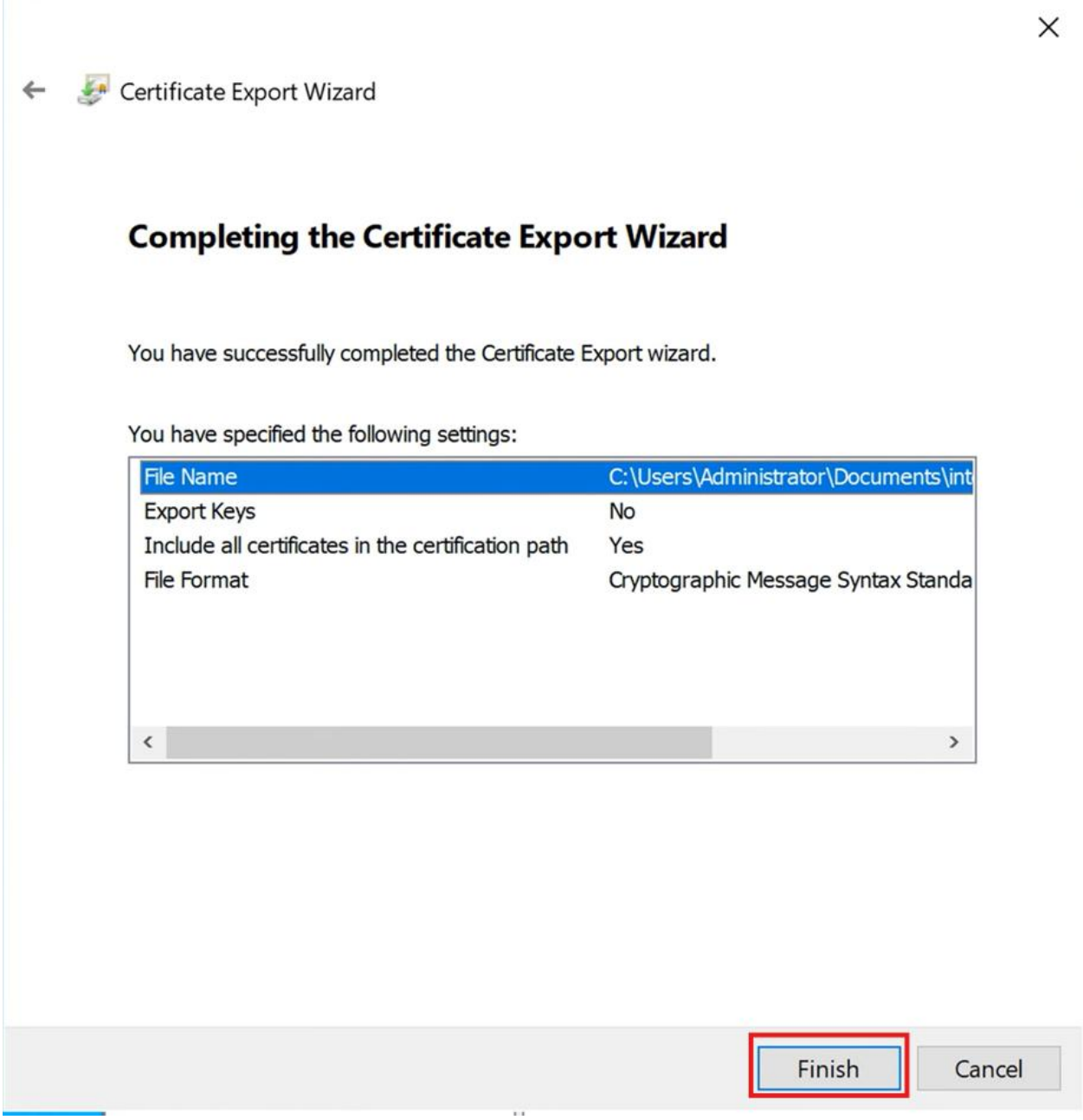
10. In the **Certificate Export Wizard**, set the format to be **Base-64 encoded X.509 (.CER)** (this format should be readable for all

[INTERNAL-ORG] devices)



11. Click **Next**
12. In the **Save As** pop-up, choose an easily-remembered location set file name as **the CA Name of the Intermediate CA Server**, click **Save**, and click **Next**

13. Click **Finish**



14. Open File Explorer and go to the location of the newly-exported **InterCa** file
15. Transfer **InterCa** onto secure media
16. Refer to SOP for importing the signed **InterCA** onto the Intermediate CA Server

Vaulting the Root CA Server

This should only be done after the Intermediate CA Server has successfully imported the (Root CA Signed) Certificate

1. Shut down the VM/physical machine
2. Secure the drive
   a. If VM, move the virtual disk to an encrypted offline drive
   b. If physical, lock it up

Vaulting is done to ensure the Root CA's private key can never be compromised, thus leading to the certificates being invalid

Clearing any old Certificate Data on ROOTCA

1. Revoke any issued certificates (the intermediate)
2. Delete any old **.cer** and **.crl** files